PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Schéma EUCC de certification

01-70 EUCC - Schéma européen de certification de cybersécurité fondé sur les critères communs — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'EUCC est un schéma de certification des produits TIC fondé sur les critères communs et les normes ISO/CEI 15408 et 18045.
2. Le schéma utilise uniquement les niveaux d'assurance substantiel et élevé, l'autoévaluation étant interdite.
3. L'ANCC surveille les schémas dans chaque État membre, l'ANSSI assurant ce rôle en France.

Cadre du Cybersecurity Act

Notion	À retenir
Règlement (UE) 2019/881	Adopté **mars/avril 2019**, publié **7 juin 2019**. Mandat permanent **ENISA** et cadre de certification. Application **directe** du règlement, mais **volontaire** pour les schémas.
Publics concernés	Fabricants/fournisseurs **TIC**, organismes d'**évaluation de la conformité**, utilisateurs finaux et **donneurs d'ordre**.
Adoption du schéma	1. Commission (programme de travail) ; 2. Requête à l'**ENISA** ; 3. Rédaction (groupe d'experts) ; 4. Revue technique (**ECCG**) ; 5. Adoption (**acte d'exécution**).
Niveaux d'assurance	**Élémentaire** (grand public, auto-évaluation) ; **Substantiel** (risque médian, organisme d'évaluation) ; **Élevé** (attaques significatives, tests de pénétration).
Autres schémas	**EUCS** (cloud, base **SecNumCloud**), **EU5G** (mise à niveau **NESAS**), **EUDI Wallet** (identité numérique).

Synthèse du schéma EUCC

Notion	À retenir
Adoption et dates	Adopté le **31 janvier 2024**, publié le **7 février 2024**. Application à partir du **27 février 2025**.
Champ et normes	Produits **TIC** (et documentation) et **profils de protection**. Normes : **ISO/CEI 15408** et **ISO/CEI 18045**.
Niveaux d'assurance	Niveaux **substantiel** (**AVA_VAN 1** ou **2**) et **élevé** (**AVA_VAN 3**, **4** ou **5**). **Autoévaluation interdite**.
Domaines techniques	**AVA_VAN 4 ou 5** seulement dans un domaine de l'annexe I (ou exception ANCC). Domaine 1 : **cartes à puce**, TPM. Domaine 2 : **boîtiers de sécurité** (terminaux de paiement, tachygraphes, HSM).

Synthèse de la certification

Notion	À retenir
La délivrance	Certificat délivré après accord sans objection du **CESTI** et de l'**organisme de certification**. Le demandeur fournit **preuves**, **code source** et procédures de **gestion des vulnérabilités**.
La marque et l'étiquette	Indiquent le **niveau d'assurance**, le **niveau AVA_VAN** et l'**identifiant unique** (nom du schéma, organisme, accréditation, date, numéro). Un **code QR** renvoie aux informations publiques.
La validité et le cycle de vie	Durée max **5 ans** pour un produit (sauf approbation **ANCC**). Un profil de protection dure autant que le profil. L'organisme peut **confirmer**, **retirer** ou **remplacer** le certificat après réexamen.

Accréditation et autorisation

Notion	À retenir
L'accréditation	L'organisme de certification suit la norme **ISO/CEI 17065**. Le **CESTI** suit **ISO/CEI 17025** et **ISO/CEI 23532-1**. Compétences : **ISO/CEI 19896-1** et **19896-3**.
L'autorisation pour le niveau élevé	L'**ANCC** doit autoriser l'organisme de certification et le **CESTI**. Évaluation : **entretiens structurés** et **certification ou évaluation pilote**. Durée ≤ accréditation. Renouvellement sans pilote.

Contrôle et sanctions

Notion	À retenir
Le contrôle	L'**ANCC** prélève chaque année au moins **4 %** des certificats (évaluation des risques). L'**organisme de certification** contrôle titulaires et produits. Le **titulaire** surveille les vulnérabilités et dépendances.
Les sanctions	**Non-conformité** : mesures correctives sous **30 jours** max. **Suspension** : **42 jours** max (prolongeable par l'**ANCC** jusqu'à **1 an** total), sans affecter la validité. **Retrait** : non-respect continu ou récurrent.

Gestion des vulnérabilités

Notion	À retenir
Les procédures	Tenir à jour des procédures (complétées par **EN ISO/IEC 30111**), publier un moyen de **signalement**, et analyser l'**impact** (calcul du potentiel d'attaque si besoin).
Le rapport et la résolution	Rapport d'impact sans retard injustifié (sans moyens d'exploitation). Corrigeable → mesure corrective + **réexamen** ; non corrigeable → **retrait** du certificat.
La divulgation	Dès le **retrait du certificat**, divulguer les vulnérabilités connues et corrigées dans la **base européenne des vulnérabilités** (**NIS 2**), selon **EN ISO/CEI 29147**.

Synthèse de la partie VII

Notion	À retenir
Archivage et publication	Archives conservées **au moins 5 ans** après retrait. Titulaire garde un **spécimen** du produit. **ENISA** publie (en **anglais**) certificats, statuts, rapports, organismes et documents.
Pays tiers et évaluation	Accord de **reconnaissance mutuelle** requis. Évaluation par les pairs des organismes **niveau élevé** tous les **5 ans** (en principe **sur place**). **ECCG** rend un avis.
Fin schémas nationaux	Effets cessent **12 mois** après l'entrée en vigueur. Certifications engagées **dans ces 12 mois** : achevées au plus tard **24 mois** après l'entrée en vigueur.
Rôle de l'ANSSI	L'**ANCC** française : surveille l'application des schémas en France, représente la France à l'**ECCG** et délivre les certificats de **niveau élevé** (comme la **CSPN**).

Pièges et confusions

- ⚠ Confondre les sept niveaux EAL des critères communs avec les cinq niveaux AVA_VAN.
- ⚠ Croire que l'EUCC permet l'autoévaluation alors qu'elle est réservée au niveau élémentaire du Cybersecurity Act.
- ⚠ Confondre l'EUCC, dédié aux produits, avec l'EUCS, dédié aux services en nuage.
- ⚠ Confondre le sigle CAB (organisme d'évaluation de la conformité) avec un comité d'approbation des changements ITIL.
- ⚠ Confondre le niveau substantiel (AVA_VAN 1 ou 2) avec le niveau élevé (AVA_VAN 3, 4 ou 5).

Sigles et définitions

EUCC	Schéma européen de certification de cybersécurité des produits TIC fondé sur les critères communs.
ENISA	Agence de l'Union européenne pour la cybersécurité qui rédige les schémas candidats et publie les certificats.
EAL	Échelle des critères communs comptant sept niveaux pour mesurer l'assurance de l'évaluation.
CESTI	Centre d'évaluation de la sécurité des technologies de l'information qui exécute les évaluations.
ANCC	Autorité nationale de certification de cybersécurité qui surveille les schémas dans chaque État membre.
OEC	Organisme d'évaluation de la conformité désignant à la fois les CESTI et les organismes de certification.
Profil de protection	Processus TIC définissant les exigences de sécurité d'une catégorie de produits, indépendamment de leur mise en œuvre.
NAB / COFRAC	Organisme national d'accréditation des OEC ; le **COFRAC** en France.

Auto-test

1. Quelle est la date d'application de l'EUCC ?
2. Quelle norme définit la méthode d'évaluation commune (CEM) ?
3. Quel est le délai maximum pour les mesures correctives en cas de non-conformité ?
4. Quel organisme accrédite les OEC en France ?
5. Quelle est la durée maximale de validité d'un certificat pour un produit ?

Réponses : **1.** 27 février 2025 · **2.** ISO/CEI 18045 · **3.** 30 jours · **4.** Le COFRAC · **5.** 5 ans

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.